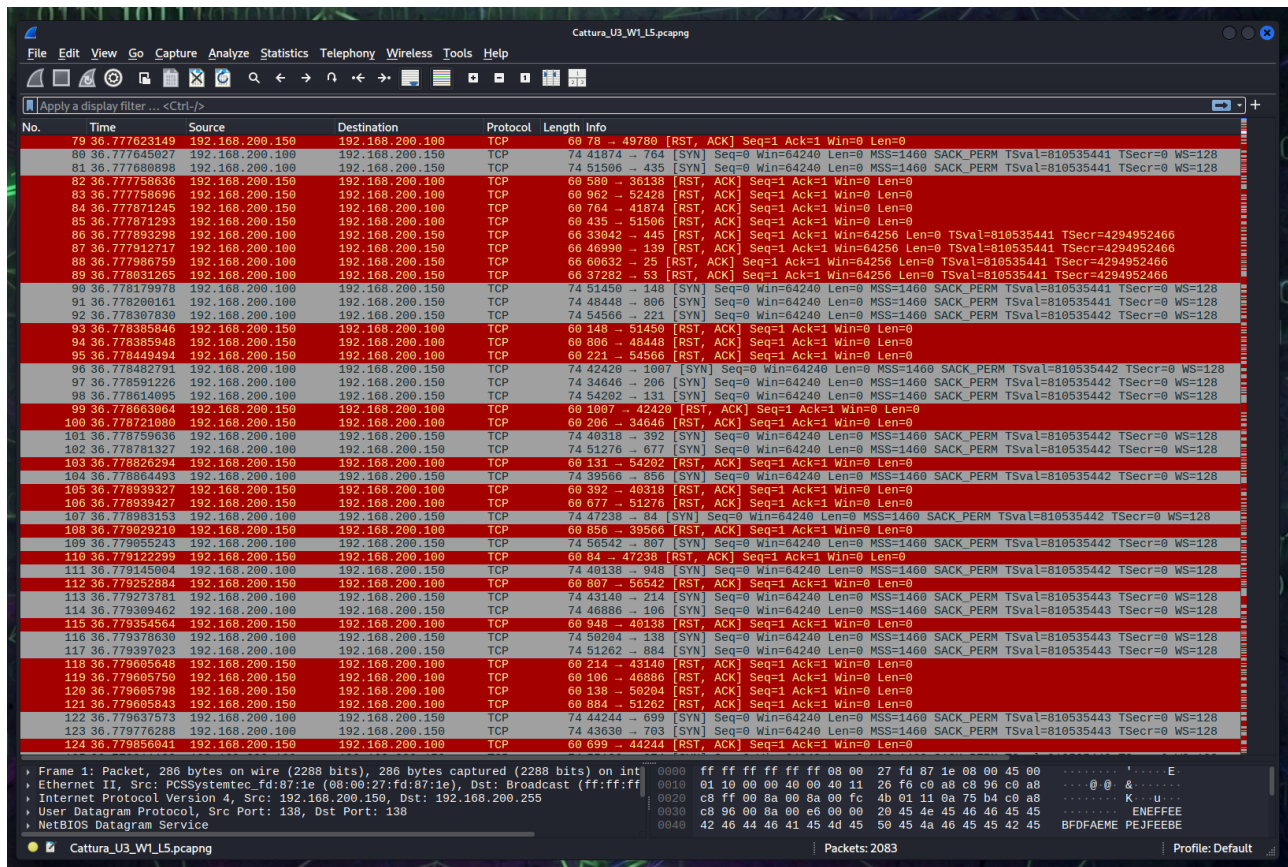


Progetto S9 – L5

Report Tecnico: Rilevamento, Analisi e Gestione di Anomalie nel Traffico di Rete

Premessa Generale e Contesto dell'Analisi

Nel contesto della sicurezza informatica, la protezione del perimetro esterno di un'infrastruttura rappresenta solo il livello iniziale di una strategia difensiva completa. È altrettanto fondamentale il monitoraggio continuo del traffico interno, ovvero delle comunicazioni che avvengono tra gli host della medesima rete aziendale. Analizzando sistematicamente i dati di rete, è possibile individuare specifici Indicatori di Compromissione (IOC), i quali segnalano comportamenti anomali che tipicamente precedono un attacco strutturato. L'analisi di tali evidenze consente di ricostruire la sequenza degli eventi, fornendo il quadro tecnico necessario per comprendere la natura della minaccia e definire tempestivamente le azioni di contenimento e mitigazione.



No.	Time	Source	Destination	Protocol	Length	Info
79	36.777623149	192.168.200.150	192.168.200.100	TCP	60	78 → 49780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
80	36.777645027	192.168.200.100	192.168.200.150	TCP	74	41874 → 784 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
81	36.777680898	192.168.200.100	192.168.200.150	TCP	74	51506 → 435 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
82	36.777758036	192.168.200.150	192.168.200.100	TCP	60	580 → 36138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
83	36.777758696	192.168.200.150	192.168.200.100	TCP	60	962 → 52428 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
84	36.777871245	192.168.200.150	192.168.200.100	TCP	60	764 → 41874 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
85	36.777871293	192.168.200.150	192.168.200.100	TCP	60	435 → 51506 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
86	36.777893998	192.168.200.100	192.168.200.150	TCP	60	33042 → 445 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
87	36.777912177	192.168.200.100	192.168.200.150	TCP	60	46890 → 139 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
88	36.777966759	192.168.200.100	192.168.200.150	TCP	60	69632 → 25 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
89	36.778031265	192.168.200.100	192.168.200.150	TCP	60	37282 → 53 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466
90	36.778179978	192.168.200.100	192.168.200.150	TCP	74	51450 → 148 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
91	36.778200161	192.168.200.100	192.168.200.150	TCP	74	48448 → 806 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSecr=0 WS=128
92	36.778307830	192.168.200.100	192.168.200.150	TCP	74	54560 → 223 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
93	36.778385946	192.168.200.150	192.168.200.100	TCP	60	148 → 51450 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
94	36.778385948	192.168.200.150	192.168.200.100	TCP	60	890 → 48448 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
95	36.778444944	192.168.200.150	192.168.200.100	TCP	60	221 → 54560 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
96	36.778482791	192.168.200.100	192.168.200.150	TCP	74	42420 → 1007 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
97	36.778591226	192.168.200.100	192.168.200.150	TCP	74	34640 → 206 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
98	36.778614095	192.168.200.100	192.168.200.150	TCP	74	54202 → 131 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
99	36.778663064	192.168.200.150	192.168.200.100	TCP	60	1007 → 42420 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
100	36.778721080	192.168.200.150	192.168.200.100	TCP	60	206 → 34640 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
101	36.778759636	192.168.200.100	192.168.200.150	TCP	74	48318 → 392 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
102	36.778781327	192.168.200.100	192.168.200.150	TCP	74	51276 → 677 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
103	36.778826294	192.168.200.150	192.168.200.100	TCP	60	131 → 54202 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
104	36.778854493	192.168.200.150	192.168.200.100	TCP	74	39560 → 856 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
105	36.778939327	192.168.200.150	192.168.200.100	TCP	60	392 → 40318 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
106	36.778939427	192.168.200.150	192.168.200.100	TCP	60	677 → 51276 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
107	36.778983153	192.168.200.100	192.168.200.150	TCP	74	47238 → 84 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
108	36.779029210	192.168.200.150	192.168.200.100	TCP	60	856 → 39560 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
109	36.779055243	192.168.200.100	192.168.200.150	TCP	74	56542 → 807 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
110	36.779122299	192.168.200.150	192.168.200.100	TCP	60	34 → 47238 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
111	36.779145094	192.168.200.100	192.168.200.150	TCP	74	40130 → 946 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535442 TSecr=0 WS=128
112	36.779252084	192.168.200.150	192.168.200.100	TCP	60	807 → 56542 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
113	36.779273781	192.168.200.100	192.168.200.150	TCP	74	43140 → 214 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
114	36.779309462	192.168.200.100	192.168.200.150	TCP	74	46886 → 106 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
115	36.779354564	192.168.200.150	192.168.200.100	TCP	60	948 → 40130 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
116	36.779378638	192.168.200.100	192.168.200.150	TCP	74	50204 → 138 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
117	36.779397023	192.168.200.100	192.168.200.150	TCP	74	51262 → 884 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
118	36.779605648	192.168.200.150	192.168.200.100	TCP	60	214 → 43140 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
119	36.779605750	192.168.200.150	192.168.200.100	TCP	60	106 → 46886 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
120	36.779605798	192.168.200.150	192.168.200.100	TCP	60	138 → 50204 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
121	36.779605843	192.168.200.150	192.168.200.100	TCP	60	884 → 51262 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
122	36.779637573	192.168.200.100	192.168.200.150	TCP	74	44244 → 699 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
123	36.779762880	192.168.200.100	192.168.200.150	TCP	74	43030 → 703 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535443 TSecr=0 WS=128
124	36.779856041	192.168.200.150	192.168.200.100	TCP	60	699 → 44244 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Frame 1: Packet, 286 bytes on wire (2288 bits), 286 bytes captured (2288 bits) on int0

Ethernet II, Src: PCSysentec_fd:87:1e (08:00:27:fd:87:1e), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

Internet Protocol Version 4, Src: 192.168.200.150, Dst: 192.168.200.255

User Datagram Protocol, Src Port: 138, Dst Port: 138

NetBIOS Datagram Service

0000 ff ff ff ff ff ff 08 00 27 fd 87 1e 08 00 45 00
0010 01 10 00 00 40 00 40 11 26 f6 c0 a8 c8 96 c0 a8
0020 c8 ff 00 8a 00 8a 00 fc 4b 01 11 0a 75 b4 c0 a8
0030 c8 96 00 8a 00 c0 00 00 20 45 4e 45 46 45 45
0040 42 46 44 46 41 45 4d 45 50 45 4a 46 45 42 45 BFDFAEME PE3FEEBE

1. Identificazione e Spiegazione degli Indicatori di Compromissione

L'esame dei tracciati di rete rivela un pattern di traffico altamente anomalo e sistematico. L'analisi dei pacchetti evidenzia una dinamica che richiede un intervento di verifica immediato:

- **Sorgente e Destinazione del Traffico:** Come visibile nelle catture (ad esempio in image_5b2973.jpg e image_5b2955.jpg), un host sorgente, identificato dall'indirizzo IP 192.168.200.100, genera un volume di richieste sproporzionato verso un singolo host di destinazione, avente l'indirizzo IP 192.168.200.150. L'appartenenza di entrambi gli indirizzi alla medesima sottorete privata (192.168.200.x) indica che l'attività ha origine internamente all'infrastruttura.
- **Caratteristiche del Protocollo:** Il traffico generato non consiste in un trasferimento di dati standard o applicativi. L'host sorgente invia quasi esclusivamente pacchetti TCP con il solo flag SYN attivato. Nel protocollo TCP, questo pacchetto rappresenta la richiesta iniziale per stabilire una connessione. Tuttavia, in questo scenario, il mittente non ha l'intento di completare la connessione formale (il cosiddetto *three-way handshake*), ma interrompe il processo non appena riceve una risposta.
- **Frequenza e Distribuzione delle Richieste:** L'invio dei pacchetti SYN avviene con una frequenza estremamente elevata, nell'ordine di frazioni di millisecondo, come confermato dai timestamp presenti nelle registrazioni (es. image_5b2938.jpg, image_5b291b.jpg e image_5b28fe.jpg). Tali richieste sono distribuite in sequenza rapida su un ampio numero di porte di destinazione diverse sull'host bersaglio, sondando sistematicamente un vasto intervallo di porte di rete.
- **Risposte dell'Host Bersaglio:** A fronte di queste richieste, l'host 192.168.200.150 risponde in modo costante inviando pacchetti TCP caratterizzati dai flag [RST, ACK]. Dal punto di vista tecnico, questa risposta comunica che la porta interrogata è in stato di chiusura e che non vi è alcun servizio logico in ascolto pronto ad accettare una connessione in quel determinato momento.

La combinazione di questi parametri tecnici identifica inequivocabilmente l'esecuzione di un **TCP SYN Port Scan**. Si tratta di una tecnica automatizzata utilizzata per mappare i servizi attivi su un sistema bersaglio, identificando le porte aperte senza completare la connessione logica. Questa modalità viene spesso impiegata per eludere le registrazioni e i log generati dai sistemi di sicurezza più elementari.

2. Analisi degli Scenari: Ipotesi sui Potenziali Vettori di Attacco

Sebbene la scansione delle porte costituisca un'attività di ricognizione che non altera né distrugge i dati di per sé, essa rappresenta la fase preliminare e critica di un attacco informatico (nella Cyber Kill Chain, questa è la fase di *Reconnaissance*). Considerando che l'attività si origina all'interno della rete locale aziendale, si delineano scenari di rischio specifici:

- **Movimento Laterale (Lateral Movement):** Rappresenta lo scenario operativo più critico. L'ipotesi principale è che l'host sorgente (192.168.200.100) sia già stato compromesso, ad esempio tramite un malware o un'azione di phishing ai danni di un utente. L'attaccante sta attualmente utilizzando questa macchina come testa di ponte (pivot) per esplorare

l'infrastruttura di rete interna. Lo scopo è identificare ulteriori sistemi attivi e ampliare il proprio livello di accesso (come il server 192.168.200.150).

- **Ricognizione per lo Sfruttamento di Vulnerabilità (Exploitation):** L'obiettivo della scansione è l'enumerazione precisa dei servizi in esecuzione sul bersaglio. Qualora l'attaccante individuasse una porta associata a un software non aggiornato o vulnerabile, il vettore d'attacco successivo consisterebbe nell'utilizzo di exploit specifici. Questo permetterebbe all'attore malevolo di ottenere l'esecuzione di codice in modalità remota (RCE) sul sistema bersaglio, prendendone il controllo tecnico.
- **Preparazione ad Attacchi basati sulle Credenziali:** Se la scansione dovesse rivelare l'esposizione di servizi di amministrazione remota (come i protocolli SSH o RDP), l'attaccante procederebbe presumibilmente con tentativi di accesso non autorizzato forzando l'autenticazione. Tali tentativi potrebbero assumere la forma di attacchi *Brute-Force* (generazione massiva di combinazioni di credenziali) o *Credential Stuffing* (utilizzo di credenziali compromesse e note), al fine di ottenere un accesso di tipo amministrativo al sistema.

3. Piano d'Azione: Strategie di Mitigazione e Prevenzione

Per neutralizzare la fase di ricognizione in corso, prevenire l'escalation dell'attacco verso la macchina bersaglio e incrementare la resilienza dell'infrastruttura nel lungo termine, si raccomanda l'adozione delle seguenti contromisure tecniche.

Fase 1: Contenimento Immediato dell'Incidente

- **Isolamento di Rete dell'Host Sorgente:** L'endpoint identificato dall'IP 192.168.200.100 deve essere immediatamente segregato dal resto dell'infrastruttura. L'isolamento logico (tramite l'assegnazione a una VLAN di quarantena) o fisico (disabilitazione della porta di rete sullo switch di accesso) interrompe istantaneamente le capacità di movimento laterale dell'attaccante. È importante non spegnere la macchina per consentire la successiva acquisizione dei dati volatili (RAM) necessari alle indagini.
- **Implementazione di Regole di Blocco:** Applicare regole restrittive (Access Control Lists) sui firewall interni o sui dispositivi di routing per eseguire il blocco (drop) di tutto il traffico in uscita dall'indirizzo IP compromesso, garantendo un ulteriore livello di protezione temporanea per l'intera rete.

Fase 2: Analisi Forense e Verifica di Integrità

- **Indagine sull'Host Compromesso:** Sottoporre l'host isolato a un'analisi forense dettagliata per determinare il vettore di infezione iniziale. È necessario identificare il metodo esatto attraverso il quale la macchina è stata compromessa (es. esecuzione di payload malevoli, sfruttamento di vulnerabilità locali) per poter procedere a una bonifica completa del sistema ed evitare reinfezioni future.

- **Verifica dei Log del Sistema Bersaglio:** Analizzare i file di log di sistema e applicativi dell'host 192.168.200.150. Lo scopo è accertare in modo definitivo che la fase di scansione non sia stata seguita da tentativi di accesso riusciti prima del nostro intervento di contenimento, verificando la totale assenza di sessioni non autorizzate o di esecuzioni di comandi anomali da parte dell'indirizzo IP investigato.

Fase 3: Consolidamento dell'Architettura di Sicurezza (Lungo Termine)

- **Adozione di Sistemi di Intrusion Detection/Prevention (IDS/IPS):** Implementare e calibrare soluzioni di sicurezza capaci di ispezionare il traffico di rete alla ricerca di pattern anomali. È necessario configurare policy che rilevino e blocchino automaticamente le frequenze di pacchetti tipiche delle scansioni di rete, intercettando e interrompendo l'attività prima che un attaccante possa completare la mappatura dei servizi dell'infrastruttura.
- **Riduzione della Superficie di Attacco (Hardening):** Applicare rigorosamente il principio del minimo privilegio a tutti i sistemi, incluso il bersaglio dell'attuale scansione. È essenziale disabilitare i servizi di rete e i demoni non strettamente necessari per l'operatività aziendale e configurare i firewall locali (host-based firewall) per accettare connessioni logiche esclusivamente dalle subnet autorizzate e necessarie.
- **Segmentazione di Rete e Modello Zero Trust:** L'evento analizzato evidenzia i gravi rischi intrinseci alle architetture di rete "piatte", dove gli host comunicano senza restrizioni. Si raccomanda di implementare una rigorosa segmentazione logica della rete, separando le workstation degli utenti dai server critici tramite rigidi controlli di accesso. L'adozione progressiva di un approccio *Zero Trust Network Access* (ZTNA) garantisce che tutte le comunicazioni interne siano soggette a verifiche costanti e stringenti, limitando drasticamente la capacità tecnica di un nodo compromesso di comunicare in modo non autorizzato con il resto dell'ambiente aziendale.

Conclusione

L'identificazione tempestiva di questo traffico anomalo di ricognizione ha permesso di interrompere la catena dell'attacco in una fase preliminare, prevenendo potenziali accessi non autorizzati e la conseguente compromissione dei sistemi bersaglio. L'evento dimostra l'assoluta necessità di estendere il monitoraggio della sicurezza ben oltre il perimetro esterno, garantendo una visibilità granulare e costante sulle dinamiche interne della rete. L'integrazione di sistemi di rilevamento avanzati basati su firme comportamentali, unita all'adozione di rigorose politiche di segmentazione e di riduzione della superficie di attacco, costituisce l'impianto strategico fondamentale per proteggere l'infrastruttura dalle minacce capaci di infiltrarsi e operare lateralmente all'interno dell'ambiente aziendale.